

STELLAR CODE

Security Division

Post-Remediation Re-Audit Report

HNTRMembership Protocol

Verification of Fixes Against Security Audit v2.0, and a Fresh Review Pass

Client	HNTR
Repository	hntr-web3
Contracts in Scope	HNTRMembership.sol, IHNTRMembership.sol
Prior Report	HNTRMembership_Security_Audit_StellarCode.pdf, v2.0, 18 July 2026
Commit / Snapshot	Working tree as provided, 22 July 2026
Target Chain	Ethereum mainnet (USDT / USDC, 6 decimals)
Toolchain	Solidity ^0.8.24/0.8.28, Foundry, OpenZeppelin Contracts v5
Verification Method	Line-by-line diff against v2.0 findings, fresh manual review, forge test (44/44 passing)
Audited by	Stellar Code Security Division
Date of Issue	22 July 2026
Version	1.0 — Re-Audit
Classification	Confidential — Client Distribution Only

3 OF 5 FINDINGS FULLY RESOLVED · 2 PARTIALLY RESOLVED · 0 NEW HIGH/CRITICAL ISSUES

Table of Contents

- 1. Purpose & Method
- 2. Executive Summary
- 3. Remediation Status Overview
- 4. Remediation Findings
 - SEC-01 Signing key compromise — Partially Fixed, Residual Medium
 - SEC-02 Ownership bound to deploying EOA — Fixed
 - SEC-03 No pause / no rescue — Fixed
 - SEC-04 Unmeasured token receipt — Partially Fixed, Residual Medium
 - SEC-05 No duplicate/self upline rejection — Fixed
- 5. New Observations From This Review
- 6. Appendix A — Non-Security Housekeeping Status
- 7. Verification Evidence
- 8. Verdict & Recommendation
- 9. Disclaimer

1. Purpose & Method

This report re-audits **HNTRMembership.sol** against the five findings raised in Stellar Code's Security Audit v2.0 (18 July 2026) to confirm which have been remediated, then performs a fresh, independent review pass to catch anything the remediation itself may have introduced or left uncovered.

Method. Each of the five original findings (SEC-01 through SEC-05) and all twenty Appendix A housekeeping items were checked line-by-line against the current source. Every claimed fix was traced to the specific code change that implements it. The full Foundry test suite (`test/HNTR.t.sol`) was then executed to independently confirm behaviour, including dedicated regression tests written for each fix. Finally, the diff itself — the new inherited contracts, modifiers, and state variables — was reviewed as new attack surface in its own right, independent of what it was meant to fix.

2. Executive Summary

Of the five findings in the original report, **three are fully resolved** (SEC-02, SEC-03, SEC-05) and **two are partially resolved** (SEC-01, SEC-04). In both partial cases, the specific failure mode that justified the original High severity rating has been closed; what remains is a lower-priority recommendation from the same finding that was not implemented. We downgrade the residual risk on both from High to Medium.

The two findings the original report called **impossible to retrofit after deployment** — SEC-02 (permanently bound ownership) and SEC-03 (no pause, no rescue) — are both now fully in place: the contract inherits `Ownable2Step` and `Pausable`, and an owner-only `rescueToken` respects a liability-floor invariant. This was the report's primary recommendation and its P0 priority item; both are done.

SEC-01's fix closes the part of the finding the original report considered most damaging — that a leaked signature batch stayed valid forever and rotating the signer key did not help. A per-user nonce and an owner-bumpable global epoch now let the owner invalidate every outstanding signature in one transaction. What remains open is the single-signer trust model itself (recommendation #4) and the move to EIP-712 (recommendation #5) — neither of which was in scope for the P0/P1 work but both of which were explicitly recommended follow-ups.

SEC-04's fix closes the insolvency path — the contract now measures what it actually received before distributing, rather than trusting the requested amount, which directly neutralises the dormant Tether fee scenario the original report singled out as the most realistic route to insolvency. The blacklisting exposure named in the same finding — a single frozen protocol wallet halting all sales — was not addressed.

NO NEW CRITICAL OR HIGH-SEVERITY ISSUE WAS INTRODUCED BY THE REMEDIATION

One new, lower-severity item surfaced during this review: `Ownable2Step` makes `transferOwnership` two-step, but `renounceOwnership()` — inherited unchanged from `Ownable` — remains a single, irreversible call that zeroes owner immediately. Because every incident-response control added for SEC-02/SEC-03 is `onlyOwner`, an accidental or coerced `renounce` would permanently disable all of them. See Section 5.

ID	Finding	Original Severity	Status	Residual
SEC-01	Signing key compromise redirects the entire commission stream	High	Partially Fixed	Medium
SEC-02	Ownership permanently bound to the deploying EOA	High	Fixed	None
SEC-03	No pause and no rescue — no incident-response capability	High	Fixed	None
SEC-04	Distribution assumed tokens received equals amount requested	High	Partially Fixed	Medium
SEC-05	No duplicate or self-referential upline rejection	Medium	Fixed	None

3. Remediation Status Overview

Metric	Result
Findings fully resolved	3 of 5 (SEC-02, SEC-03, SEC-05)
Findings partially resolved	2 of 5 (SEC-01, SEC-04) — residual risk downgraded High → Medium
Findings unresolved / worsened	0 of 5
New critical / high findings from this review	0
New medium/low observations from this review	1 — see Section 5
Regression tests passing	44 / 44 (test/HNTR.t.sol, `forge test`)
P0 items (cannot be retrofitted post-deploy) completed	2 of 2 (Ownable2Step, Pausable+rescueToken)
Appendix A housekeeping items resolved	5 of 20 fully, 2 of 20 partially

Every fix below was verified against the specific code location cited in the v2.0 report and against a dedicated regression test added to the suite for that fix. Section 7 lists the exact tests referenced throughout this report.

4. Remediation Findings

SEC-01 Signing key compromise redirects the entire commission stream

PARTIALLY FIXED

Original Severity	High
Residual Severity	Medium
Location	HNTRMembership.sol L49–53, L249–276, L118–121

Fixed

A per-user nonces mapping is now committed into the signed hash and incremented on every successful purchase or upgrade — a leaked signature can no longer be replayed once consumed (recommendation #1).

A global `signatureEpoch` was added, bumped in one transaction by owner-only `invalidateSignatures()`. This closes the finding's most damaging property: previously, a leaked batch of signed payloads stayed valid until each individually expired and rotating the signer did not help. Now the owner can invalidate every outstanding signature at once (recommendation #2).

Still Open

Recommendation #4 (multiple, individually-revocable signers via a signer registry) was not implemented. Authorization still rests on a single `companyWallet` address — a compromise still redirects 100% of future commission flow until the owner reacts.

Recommendation #5 (EIP-712 typed data) was not implemented. The payload is still hashed and signed as an opaque EIP-191 `personal_sign` digest via `MessageHashUtils.toEthSignedMessageHash`, so a signer using a hardware wallet still cannot see a human-readable summary of what is being authorized.

Recommendation #3 (short deadlines) is not enforced on-chain — `deadline` remains fully caller-supplied with no ceiling, so an operator can still sign a payload valid for months.

Verification

Confirmed via `test_NonceIncrementsAndBlocksReplay` and `test_InvalidateSignaturesBumpsEpoch` in the current test suite; both pass.

Assessment

Downgraded from High to Medium. The unrecoverable-leak scenario that drove the original High rating is closed. The residual exposure — a single off-chain key with full authority until rotated — was already the subject of the finding's lower-priority recommendations and is unchanged in kind, not severity.

SEC-02 Ownership permanently bound to the deploying EOA

FIXED

Original Severity	High
Residual Severity	None
Location	HNTRMembership.sol L11, L15, L93

Fixed

The contract now inherits OpenZeppelin Ownable2Step in place of a hand-rolled owner variable, giving a two-step, typo-safe ownership handover via `transferOwnership` / `acceptOwnership`.

The deployment script (`script/DeployHNTRMembership.s.sol`) was updated to call `transferOwnership` to an `OWNER_MULTISIG` environment address immediately post-deploy when configured, requiring the multisig to explicitly accept before it gains control — exactly the recommended remediation.

Verification

Confirmed via `test_Ownable2Step`, which exercises the full transfer/accept cycle and asserts the prior owner loses access afterward.

Assessment

Fully resolved. This was one of the two findings the original report classified as impossible to retrofit after deployment; it is now in place before mainnet launch.

SEC-03 No pause and no rescue — no incident-response capability

FIXED

Original Severity	High
Residual Severity	None
Location	HNTRMembership.sol L12, L15, L109–115, L146–158, L172, L201

Fixed

OpenZeppelin Pausable is now inherited. whenNotPaused gates both purchaseMembership and upgradeMembership; withdrawCommissions is deliberately left unpausable, exactly matching the recommendation that a pause must never be able to trap member funds.

An owner-only rescueToken function was added. For USDT/USDC it enforces the recommended invariant — the post-rescue balance can never drop below totalWithdrawable[token], a running total of outstanding member liabilities maintained on every commission credit and withdrawal. Arbitrary other tokens sent to the contract by mistake can be swept freely.

Verification

Confirmed via test_PauseBlocksEntryUnpauseRestores, test_PauseBlocksUpgrade, test_RescueRespectsLiabilities, and test_RescueWrongTokenUnrestricted.

Assessment

Fully resolved. This was the second finding the original report classified as impossible to retrofit after deployment; both P0 items are now complete.

SEC-04 Distribution assumed tokens received equals amount requested**PARTIALLY FIXED**

Original Severity	High
Residual Severity	Medium
Location	HNTRMembership.sol L290–301

Fixed

`_processPaymentAndDistribution` now snapshots `balanceOf(address(this))` immediately before and after the `safeTransferFrom` pull, and distributes the measured delta (received) rather than the requested amount. This closes the finding's primary risk: a dormant transfer fee (e.g. Tether's `basisPointsRate`) can no longer make the contract distribute more than it holds and silently draw down other members' balances.

Still Open

The blacklisting half of this finding was not addressed. `treasuryWallet`, `leadershipWallet`, `achievementWallet`, and `poolWallet` still receive direct `safeTransfer` calls inside the purchase/upgrade path. If USDT or USDC ever freezes any one of those four addresses, every subsequent purchase and upgrade reverts — a full revenue halt — until the owner calls `setWallets` to redirect. No pull-payment fallback was added.

Verification

Confirmed via `test_FeeOnTransferDistributesReceived`, which deploys the contract against a mock token charging a 0.1% transfer fee and asserts the solvency invariant (contract balance $\geq$ total outstanding liabilities) still holds.

Assessment

Downgraded from High to Medium. The insolvency vector — the more severe of the two risks in this finding — is closed and directly verified under an adversarial token. The frozen-wallet halt vector remains, now partially mitigated operationally: the owner can pause the contract (SEC-03) and redirect the affected wallet (pre-existing `setWallets`) while a fix is arranged, where previously there was no pause at all.

SEC-05 No duplicate or self-referential upline rejection

FIXED

Original Severity	Medium
Residual Severity	None
Location	HNTRMembership.sol L278–288

Fixed

A new `_validateUplines` check runs before signature verification and rejects `address(0)`, `upline == payer`, and any duplicate address appearing earlier in the array. An attacker holding a compromised signing key (SEC-01) can no longer funnel an entire sale's 65% commission to one address or to the buyer themselves — the defense-in-depth control recommended in the original finding is now in place.

Verification

Confirmed via `test_RejectSelfUpline`, `test_RejectZeroUpline`, and `test_RejectDuplicateUpline`.

Assessment

Fully resolved.

5. New Observations From This Review

The remediation diff itself was reviewed as new attack surface, independent of the findings it was written to fix. One item is worth tracking; everything else introduced by the fix set was verified clean.

5.1 Single-step renounceOwnership remains a footgun

`Ownable2Step` only makes `transferOwnership` two-step; `renounceOwnership()`, inherited unchanged from `Ownable`, still sets owner to `address(0)` immediately, in a single call, with no acceptance step and no way to reverse it.

Every control added for SEC-02 and SEC-03 — `pause/unpause`, `setWallets`, `setCompanyWallet`, `invalidateSignatures`, and `rescueToken` — is `onlyOwner`. An accidental or coerced renounce, once ownership sits with a multisig, permanently disables all of them with no recovery path.

Recommendation. Override `renounceOwnership` to revert unconditionally, unless intentional permanent decentralisation is a desired end state for this protocol — which the trust model in the original report suggests it is not.

5.2 Areas reviewed and found clean

The following aspects of the new code were specifically checked and found not to introduce risk: reentrancy interaction between the new `nonReentrant` guards and the existing external-call pattern in `_processPaymentAndDistribution`; correct placement of the nonce increment before external calls (effects-before-interactions is preserved); no overflow risk in `signatureEpoch` or nonces (`uint256`, unreachable in practice); gas cost of the new $O(n^2)$ upline-uniqueness check, bounded by the new `MAX_UPLINES = 64` cap to a few thousand gas at worst; and correctness of the `rescueToken` liability invariant against the same solvency proof verified in the original report.

6. Appendix A — Non-Security Housekeeping Status

None of the twenty Appendix A items from v2.0 gate deployment; they are tracked here for completeness. Five were resolved as a direct byproduct of the security fixes above; two more were partially improved; the rest are unchanged.

#	Observation	Status
1	setWallets / setCompanyWallet accepted address(0)	Fixed
2	withdrawCompanyWallet's 30-day guard short-circuits on lastClaimedAt == 0	Open
3	getOverdueWallets scans an unbounded array twice (DoS past ~3–4k members)	Open
4	Tier prices are immutable, no setter	Open (by design)
5	uplines array length was uncapped	Fixed — MAX_UPLINES = 64
6	lockedCommissions records lifetime accrual, not outstanding share	Open
7	6-decimal price assumption was unenforced in code	Fixed — constructor requires decimals() == 6
8	No ReentrancyGuard	Fixed — nonReentrant on all state-changing entry points
9	Rounding dust permanently unrecoverable	Fixed — via rescueToken
10	withdrawCompanyWallet double-emits for one movement	Open
11	require(price > 0, ...) is unreachable dead code	Open
12	Redundant user parameter given msg.sender == user	Open (design choice)
13	Events under-indexed	Open
14	Config events emit only new values, no before/after	Open
15	Floating pragma ^0.8.24	Open
16	Interface omits the administrative surface	Open — now also missing pause/rescueToken/invalidateSignatures
17	onlyCompanyWallet on a view function provides no real confidentiality	Open
18	String revert reasons instead of custom errors	Open
19	Unused MockSeaport/MockSwapRouter; MockERC20 was 18-decimal	Partially fixed — MockERC20 now 6-decimal, unused mocks remain
20	Sparse NatSpec	Partially improved — inline fix-site comments added, no formal NatSpec

7. Verification Evidence

All 44 tests in `test/HNTR.t.sol` pass under `forge test`, including the following tests written specifically to regression-test the fixes covered in this report:

Finding	Regression Tests
SEC-01	<code>test_NonceIncrementsAndBlocksReplay</code> , <code>test_InvalidateSignaturesBumpsEpoch</code> , <code>test_CrossOperationReplayBlocked</code> , <code>test_ExpiredSignatureReverts</code> , <code>test_WrongSignerReverts</code>
SEC-02	<code>test_Ownable2Step</code> , <code>test_OnlyOwnerAdmin</code>
SEC-03	<code>test_PauseBlocksEntryUnpauseRestores</code> , <code>test_PauseBlocksUpgrade</code> , <code>test_RescueRespectsLiabilities</code> , <code>test_RescueWrongTokenUnrestricted</code> , <code>test_RescueZeroRecipientReverts</code>
SEC-04	<code>test_FeeOnTransferDistributesReceived</code> , <code>test_SolvencyInvariantAfterWithdraw</code>
SEC-05	<code>test_RejectSelfUpline</code> , <code>test_RejectZeroUpline</code> , <code>test_RejectDuplicateUpline</code> , <code>test_TooManyUplinesReverts</code>

```
Ran 44 tests for test/HNTR.t.sol:HNTRMembershipTest
...
Suite result: ok. 44 passed; 0 failed; 0 skipped

Ran 1 test suite: 44 tests passed, 0 failed, 0 skipped (44 total tests)
```

8. Verdict & Recommendation

The two findings the original report flagged as deployment-blocking because they could not be fixed after the fact — SEC-02 and SEC-03 — are both fully resolved and covered by passing tests. SEC-05 is fully resolved. SEC-01 and SEC-04 each had their unrecoverable failure mode closed and retain only the lower-priority recommendation from their original finding, which we now track as Medium-severity follow-up work rather than launch-blocking risk.

No new critical or high-severity issue was introduced by the remediation itself. The single new item — the unrestricted `renounceOwnership` call — is cheap to fix and becomes relevant only once ownership moves to the recommended multisig.

NO DEPLOYMENT BLOCKERS REMAIN

Recommendation. Proceed with the remaining follow-up items as hardening rather than launch blockers: multi-signer support and EIP-712 typed data for SEC-01, and a pull-payment pattern for the four protocol wallets for SEC-04. Consider overriding `renounceOwnership` before or shortly after moving ownership to a multisig. Re-run the full test suite after any further change, and consider commissioning a follow-up review once multi-signer support and EIP-712 land, given that SEC-01 is the finding with the widest blast radius in the protocol.

9. Disclaimer

This report is provided by Stellar Code on an “as is” basis and reflects the state of the reviewed source code at the time of this re-assessment. It supplements, and should be read alongside, the original Security Audit v2.0 (18 July 2026) — findings, scope notes, and disclaimers from that report remain in effect except where explicitly updated here. A security audit is a best-effort, time-boxed activity and cannot prove the absence of vulnerabilities. It is not a warranty, guarantee, endorsement, or investment advice.

The assessment covered `src/HNTRMembership.sol` and `src/IHNTRMembership.sol` only. The off-chain signing backend, front-end, key-management practices, deployment infrastructure, and the economic sustainability of the commission model remain outside scope. Any modification to the reviewed code after 22 July 2026 invalidates the findings in this report.

This document is confidential and intended solely for the named client. Redistribution requires written consent from Stellar Code.

Stellar Code — Security Division

Report v1.0 · Issued 22 July 2026 · Confidential